IY3501: Security Management

– FOR FIRST SITS/RESIT CANDIDATES

Time allowed: **THREE hours** (including upload time)

- Answer **QUESTION 1** and **TWO** additional questions.
  No credit will be given for attempting any further questions.

- Handwrite your answers on paper, and write the module number and your candidate number at the top of each page. Photograph/scan the pages and keep the original paper versions, as they may be required by the examiners.
- For each question you attempt, please clearly state the question number.
- Please do not include your name or Student ID Number anywhere on your work.
- **Academic Misconduct:** We will check all assignments for academic misconduct. Suspected offences will be dealt with under the College's formal Academic Misconduct procedures. Please remember:
  - The work submitted is expected to be your own work and only your work. You may not ask for help with the assessments from any source, or copy anyone else's work.
  - You must not give help to anyone else, including sending them any parts of the questions or copies of your solutions, even after the 23-hour time period has finished.

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

NEXT PAGE

- **Submitting your work:**
  - Your document must be submitted through Moodle using the submission link in the module Moodle page. If possible please convert your document into a PDF document before submitting to make the upload process quicker and easier.
  - If you run into technical difficulties with uploading, email

    `EPMS-AAquery@rhul.ac.uk`

If you have any questions in relation to completing the assessment or if you have any difficulty completing this assessment on time please e-mail us at

`EPMS-AAquery@rhul.ac.uk`

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 1. (This question is **COMPULSORY**)

The following security breach has been widely reported:

British Airways has been fined twenty million pounds by the Information Commissioner's Office (ICO) for a data breach which affected more than 400,000 customers. This is the commissioner's first major fine under the EU data regulation GDPR. Attackers stole data including log in, payment card and travel booking details as well name and address information.

The incident took place when BA's systems were compromised by its attackers, and then modified to harvest customers' details as they were input. It was two months before BA was made aware of the incident by a security researcher, who then notified the ICO.

A subsequent investigation concluded that sufficient security measures, such as multi-factor authentication, were not in place at the time. It was noted that some of these measures had been available on the Microsoft operating system that BA was using at the time.

British Airways said it had alerted customers as soon as it had found out about the attack on its systems. "We are pleased the ICO recognises that we have made considerable improvements to the security of our systems since the attack and that we fully co-operated with its investigation," said a spokesman.

Source: `https://www.bbc.co.uk/news/technology-54568784`.

(a) Explain how this security breach can be seen as breach of GDPR. [5 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

(b) (i) Define the term 'security culture'. [2 marks]

(ii) Give **TWO** reasons why having a positive security culture is important for information security. [4 marks]

(iii) What might we conclude from this breach about BA's security culture? [5 marks]

(c) Give **ONE** example of a possible weakness in BA's incident management process that could be deduced from this breach. [6 marks]

(d) Discuss **TWO** lessons that can be learnt from this breach. In each case indicate what you think BA did wrong, and what they might have done to handle things better. [12 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2. (a) Give a definition for the term 'Information Security Management System (ISMS)'. [3 marks]

(b) A common approach to information security management starts with setting out certain security goals. Imagine you are responsible for security management for an online streaming service.

(i) Identify **THREE** possible security goals for this business. [3 marks]

(ii) For each security goal, give an example of its meaning in the context of this business. [6 marks]

(iii) Give **TWO** examples of possible changes in circumstances that would lead to revisiting the security goals as part of the continued improvement of the ISMS. [8 marks]

(c) Another approach to information security management starts with considering certain threats. Imagine that you are responsible for security management for an energy supplier.

(i) Identify **ONE** possible business goal of the energy supplier. [2 marks]

(ii) Describe **THREE** threats that could put the business goals at risk. [12 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3. (a) ISO/IEC 27001 and ISO/IEC 27002 are widely used information security management standards.

(i) Outline the process by which an organisation might become ISO/IEC 27001 certified. [3 marks]

(ii) Explain the role of the Statement of Applicability in relation to ISO/IEC 27001 and ISO/IEC 27002. [2 marks]

(b) Consider the statement: 'ISO/IEC 27001 is simply common sense, and hence a waste of time'. Do you agree or disagree with this statement? Justify your answer. [6 marks]

(c) A control is a measure to modify risk.

(i) Give **ONE** example of a control that increases risk. In your answer, explain the purpose of the control and how it may damage security. [5 marks]

(ii) Give **TWO** examples of controls that someone may implement on their personal mobile phone. For each example, justify why this control is useful. [6 marks]

(d) Other than the modification of risk with security controls, describe three options for risk treatment. For each option, give an example of a risk for

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

which this may be the most appropriate treatment, making reference to a specific business context. [12 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4. (a) The risk of an event can be measured by considering the likelihood of the event occurring and the impact that the event would have.

(i) Explain what is meant by a qualitative risk evaluation. [2 marks]

(ii) Give an advantage and a disadvantage of a qualitative risk evaluation as opposed to a quantitative risk evaluation. [4 marks]

(iii) Describe **ONE** scenario for which a qualitative risk evaluation would be more appropriate than a quantitative risk evaluation. [3 marks]

(b) State the five main phases of managing an information security incident. [5 marks]

(c) Describe **THREE** ways in which the knowledge gained from analysing and resolving information security incidents could inform the risk management process. [9 marks]

(d) Explain the difference between business continuity and disaster recovery. [5 marks]

(e) Backup can be thought of as part of business continuity planning. Consider the statement: 'The advent of cloud removes the need for backup'. Do you agree or disagree with this statement? Justify your answer. [6 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

END

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.